

KSA Compliance Roadmap

SECTION 04-compliance-ksa TYPE plan STATUS **draft** OWNER Founder UPDATED 2026-08-20*Status: draft (sequenced) · Created: 2026-06-16 · Rewritten: 2026-07-03 · Owner: Founder*

Not legal or regulatory advice, and not a statement of certified compliance status. Statuses below are the founder's operational tracking, sequenced against `../00-strategy/ceo-execution-roadmap-2026-07.md` (Sprints 0–3) and `../02-legal/launch-gate-legal-checklist-2026-06-14.md` (gates L0–L3). Every filing must be confirmed against the relevant Saudi authority before reliance. Items marked **[Owner to confirm]** are open unknowns.

Purpose

A diffable index and status tracker over the KSA regulatory pack — what each filing is, who owns it, its current state, and what gates it blocks. The binding detail lives in the `.docx` deliverables listed below. Company context: solo founder operating through **BDA Company International** (شركة بدع الدولية) — LLC, CR 7030976893 (active), VAT-registered (311415259500003, quarterly) with a business bank account open; see `../01-governance/company-facts.md`. Still pre-revenue; the first revenue motion is B2B school pilots invoiced manually (ZATCA-compliant e-invoice) per DEC-009.

The dependency chain (from the CEO execution roadmap)

Lawyer opinion → NAME LOCKED → CR ✓ → Bank account ✓ → ZATCA VAT ✓ + Fatoora → Payment gateway → Paywall flip (L2)
(2026-07-27: CR, bank and VAT registration are DONE — the chain's remaining gates are the lawyer opinion, Fatoora onboarding, the payment gateway and the paywall flip.)
Parallel: PDPL DPIA specialist review → public user accounts (L1)
Parallel: B2B pilot → manual ZATCA e-invoice → first revenue (pre-Fatoora-onboarding)

Hard deadline: 12 Aug 2026 — the new Saudi Copyright Law + SAIP implementing regulations take effect; the lawyer opinion (Sprint 0/1) must account for it.

Registrations & licensing

Item	Deliverable	Owner	Status	Blocks
Commercial Registration (CR)	Saudi Business Center filing — result logged in <code>../00-strategy/phase0.md</code> (P0-3)	Founder	DONE — شركة بدع الدولية / BDA Company International, LLC, unified number 7030976893, issued 23/09/2022, active. Structure question settled: LLC	Unblocked: bank ✓, ZATCA VAT ✓, Monshaat, NTDP, entity-name contracts

Item	Deliverable	Owner	Status	Blocks
MISA investment license	misa-investment-license-application-bundle.docx	Founder	Not required — the entity is a 100%-Saudi-owned LLC registered via the Saudi Business Center; MISA licenses foreign investment. Bundle kept for reference only (the SAR 60k/yr line in the tax calendar has been corrected accordingly)	Nothing
Monshaat SME registration	monshaat-sme-registration-kit.docx	Founder	Not started — Blocked-by-CR (Sprint 2.2)	SME support programs only; nothing downstream
NTDP application	ntdp-application.docx	Founder	Not started — Blocked-by-CR ; eligibility check scheduled Sprint 2.2	Grant/support funding only
Tamheer & Doroob	tamheer-and-doroob-program-application-pack.docx	Founder	Not started — not applicable pre-entity and pre-hire; no hires planned this quarter	First-hire onboarding only

Tax & invoicing

Item	Deliverable	Owner	Status	Blocks
VAT compliance	vat-compliance-memo.docx	Founder	Memo drafted; registration Not started — Blocked-by-CR + bank account (Sprint 3.1)	Fatoora onboarding; consumer checkout (L2)
ZATCA Fatoora e-invoicing	zatca-fatoora-e-invoicing-compliance-pack.docx	Founder	Pack drafted, not implemented. Interim: first B2B pilot invoice is issued as a manual ZATCA-compliant e-invoice (Sprint 2.5, per <code>../07-gtm/b2b-pipeline.md</code>). Full Fatoora onboarding is Sprint 3.1, Blocked-by-VAT-registration	First B2B revenue (manual path); paywall flip (integrated path)
Tax/compliance calendar	saudi-tax-and-compliance-calendar.docx	Founder	Drafted — activates as an operational tracker on CR issuance	Nothing; tracking aid

Workforce

Item	Deliverable	Owner	Status	Blocks
Saudization (Nitaqat)	saudization-nitaqat-compliance-plan.docx	Founder	Plan drafted; not applicable pre-entity / pre-first-employee . Revisit at first hire (likeliest: paid help on ZATCA/payments integration or Arabic legal-page review, per CEO roadmap risk checkpoints)	Nothing until first employee

Data protection & security

Item	Deliverable	Owner	Status	Blocks
PDPL program & DPIA	pdpl-compliance-program-and-dpia.docx	Founder	In progress — internally drafted and founder-signed; awaiting PDPL-specialist / SDAIA-qualified counsel review (parallel track, Sprint 2.4; checklist item P0-6/L-3)	Public user accounts (L1); AI features for account holders. Does not block the B2B pilot motion
Information security	information-security-policy.docx	Founder	Drafted (ISO 27001 / CITC-aligned)	B2B security questionnaires; institutional customers
Sub-processors / DPA register	sub-processor-list-and-dpa-register.docx	Founder	Partial — review needed (confirm Google Cloud — Cloud Run / Cloud SQL / Cloud Storage — Google Gemini, Cloudflare and Moyasar are listed; checklist P1-7). Payment processor entry is settled: Moyasar (DEC-010) — Stripe was never shipped and no Stripe code exists	Accounts launch (L1); every signed B2B DPA (../02-legal/b2b-data-processing-agreement-draft-2026-06-14.md Part 5 references this register)
Data residency (in-Kingdom)	../06-operations-it/hosting-facts.md + the me-central2 migration	Founder	OPEN — regressed . Not in-Kingdom: application in me-central1 (Doha, Qatar), Cloud SQL in us-east4 (N. Virginia), verified 2026-08-19. Blocked on a Google grant for me-central2 — the region is not available to the account. See the data-residency note below	Any in-Kingdom residency representation: privacy notice publication, L1 accounts launch, every signed B2B DPA, investor/GTM residency claims
Vendor management	vendor-management-policy.docx	Founder	Drafted	—
Business continuity / DR	business-continuity-and-disaster-recovery-plan-bcp-dr.docx	Founder	Drafted	Institutional B2B due diligence only

Item	Deliverable	Owner	Status	Blocks
PCI DSS scope & SAQ	pci-dss-scope-and-saq-determination.md	Founder	Draft — no cardholder data touches our systems, but the Moyasar widget is a JS embed on our own checkout page, so SAQ A is not automatic. v4.0.1 req. 6.4.3 (payment-page script inventory + integrity) and 11.6.1 (tamper detection) are live obligations and currently unmet [Owner to confirm SAQ type with Moyasar + acquirer]	B2B security questionnaires; acquirer onboarding
PIA — Instructor Dashboard	pdpl-pia-instructor-dashboard.md	Founder / DPO	Draft — unsigned. Assesses the cross-user reads the dashboard introduces; the <code>.docx</code> DPIA covers Captain Adel only. Must be signed before the dashboard ships	Instructor Dashboard launch (L1/L3)
Cyber risk assessment	cyber-risk-assessment-2026-08.md	Founder	Draft — NIST SP 800-30 Rev 1, 11 risks scored on the risk-register scale. Feeds RR-013 / RR-021 / RR-014 and proposes five new rows	ISO 27001 Clause 6.1.2 input; investor DD
ISMS scope & SoA	isms-scope-and-statement-of-applicability.md	Founder	Draft — Clause 4.3 scope + Statement of Applicability over all 93 Annex A controls. Readiness artefact, not a certification claim (2027 target)	B2B security questionnaires asking "what is your ISMS scope?"

Launch gates

Cross-reference `../02-legal/launch-gate-legal-checklist-2026-06-14.md` :

Gate	Event	Hard compliance gates from this roadmap
L0 — soft open (free library)	Public access, no accounts	None from this pack (legal-track items P0-1...P0-5 gate L0)
L1 — accounts launch	Registration, free tier	PDPL DPIA specialist sign-off ; sub-processor register current
L2 — payments launch	Paid subscriptions online	CR → bank → ZATCA VAT → Fatoora → payment gateway — the full chain above
L3 — Academy B2B (contracted)	Signed school deals	Manual ZATCA e-invoice capability (available pre-L2); signed DPA per customer

Monetization gate (per `../03-finance/monetization.md`): online checkout cannot open until the legal entity exists; B2B schools can be quoted and manually invoiced first.

Sequenced narrative

Q3 2026 (now — the critical-path quarter)

- **Sprint 0, wk of 2026-07-02:** lawyer brief out to 2–3 shortlisted firms (DEC-007). No compliance filings possible yet — everything registration-shaped is gated on the name.
- **Sprint 1, to 07-30:** engage one firm; receive the written opinion (corpus rights + name, accounting for the **12 Aug 2026** copyright law); **lock the name** (DEC-008).
- **Sprint 2, 07-30 → 08-27:** register the **CR** (sole-prop vs LLC decided first); open the **bank account**; submit **Monshaat** and check **NTDP** eligibility; complete the **PDPL DPIA** review in parallel; issue the **first manual ZATCA e-invoice** against a converted school pilot.
- **Sprint 3, 08-27 → 09-24:** **ZATCA VAT registration + Fatoora onboarding; Moyasar** payment gateway live (DEC-010 — mada, Apple Pay, cards); payroll flip.

Q4 2026 (post-entity consolidation)

- Fatoora issuing on every transaction; tax/compliance calendar live against real filing dates; first VAT return cycle.
- Arabic versions of P0/P1 legal documents (counsel to confirm if legally required — checklist L-4); SAIP trademark application (post name opinion, checklist L-5).
- Sub-processor register finalized against Moyasar as the payment processor of record.
- Saudization/Tamheer revisited only if the first hire happens.

2027 (growth-stage items)

- External PDPL audit by a certified KSA privacy consultant (after 3+ months of account data); NCA Essential Cybersecurity Controls alignment; penetration test before institutional/government academy customers. (Checklist Table 7.)

Data-residency note — NOT in-Kingdom today

[!CAUTION] **Target, not deployed.** The **me-central2 (Dammam, Saudi Arabia)** placement — a single Express service on Cloud Run with a co-regional Cloud SQL instance — is the **intended** architecture, and it is what the PDPL in-Kingdom residency posture is *designed* to rest on. It has **never been deployed**. Verified against `gcloud` on **2026-08-19**:

- No `flygaca-api` Cloud Run service exists in any project. Production is still the **previous Firebase Functions stack** — 14 individual Cloud Run services in project `flygaca-sa`, all in `me-central1`, which is Doha, Qatar (outside the Kingdom).
- Persistence is Cloud SQL `flygaca-sa-instance` (**PostgreSQL 18**) in `us-east4` — **Northern Virginia, USA**. A second instance, `flygaca-fdc`, is in `me-west1` (Tel Aviv).
- `me-central2` is not available to this Google account. `gcloud` returns *"Permission denied on 'locations/me-central2' ... Access to the region is unavailable. Please contact our sales team."* The migration is blocked on a Google region grant.

Consequence: customer personal data is not in the Kingdom today. The application runs in Qatar and the database in the United States. Every document in this tree that asserts in-Kingdom residency as current fact is wrong until the migration lands — including the privacy notice and the B2B DPA schedule, both of which have been corrected (`../02-legal/privacy-notice-full-stage-draft-2026-06-14.md` §5.1, `../02-legal/b2b-data-processing-agreement-draft-2026-06-14.md` §5.1).

Google Gemini AI inference is a **further, separate** gap: it runs against the Gemini API rather than on infrastructure we operate, and its processing region is **[Owner to confirm]** before any in-Kingdom claim is made for AI processing. Canonical as-built inventory: `../06-operations-it/hosting-facts.md`. See also `../06-operations-it/repo-health-report-2026-06-16.md` §2.1 and `../06-operations-it/runbooks/runbook-pdpl-me-central2.md` (the runbook describes the target migration, not a completed one).

Prior internal disagreement — now settled against the live project. `hosting-facts.md` asserted **me-central2**; the runbook and `../06-operations-it/secrets-and-keys-placement.md` said compute was still in **me-central1**. The `gcloud` inventory of 2026-08-19 settles it: **me-central1 is correct for compute**, and the database is further out still, in `us-east4`. Carried as risk **CR-09** in `cyber-risk-assessment-2026-08.md` — which should be re-scored upward, since the exposure is confirmed rather than merely suspected.

Open questions

- ~~MISA Resolved 2026-07-27~~: not required — CR via the Saudi Business Center is the complete entity path for a 100%-Saudi LLC.
- ~~Sole proprietorship vs LLC~~ **Resolved 2026-07-27**: LLC (CR 7030976893).
- ~~Stripe vs Moyasar as the live processor~~ **Resolved 2026-08-19**: **Moyasar** is the gateway of record (DEC-010; mada, Apple Pay, cards). Stripe was never shipped and no Stripe code

exists — `../06-operations-it/secrets-and-keys-placement.md` §4 says so plainly, and the shipping checkout loads only the Moyasar payment form (`ay2m/FlyGACA:src/pages/checkout/Checkout.tsx`). Carry Moyasar into the sub-processor register and the Fatoora integration; see `pci-dss-scope-and-saq-determination.md` .

- **[Owner to confirm]** VAT registration threshold/timing: mandatory vs voluntary registration point for the expected first-year revenue (~SAR 120k B2B ARR logic — 10 Cohort packages at SAR 12,000; see `../03-finance/monetization.md`).
- **me-central2 migration date (Google access grant) — RE-OPENED 2026-08-20.** The 2026-08-19 entry that marked this resolved was wrong: nothing is deployed in me-central2. A `gcloud` inventory the same day found production still on the previous Firebase Functions stack — 14 Cloud Run services in `flygaca-sa` , all in **me-central1 (Doha, Qatar)** — with Cloud SQL in **us-east4 (Northern Virginia)**. **Blocker:** `me-central2` **is not granted to this Google account** ("Access to the region is unavailable. Please contact our sales team."), so the migration cannot even be attempted. **Next action: open a Google Cloud sales/support request for `me-central2` access and record the ticket here.** This is the single hardest gate on the in-Kingdom residency claim, and it blocks L1 (accounts launch) representations, the privacy notice's publication, and every signed B2B DPA.
- **[Owner to confirm]** the processing region for **Google Gemini** inference, since the account-stage PDPL posture for AI queries depends on it. Separate from, and additional to, the me-central2 gate above.

Living doc — bump statuses each sprint. Companion to `../00-strategy/ceo-execution-roadmap-2026-07.md` and `../02-legal/launch-gate-legal-checklist-2026-06-14.md` .